

RAPPORT DE SCAN DE SÉCURITÉ

Application Web – <https://box5g.topnet.tn/>

Cible analysée: 192.168.77.26

Outil réseau: Nmap 7.95 / Zenmap

Outil Web : OWASP ZAP 2.17.0

Type d'analyse : Analyse de surface d'exposition + analyse de sécurité Web

Statut : Rapport technique pour traitement des constats

1. Objet du rapport

Le présent rapport restitue les résultats des analyses de sécurité réalisées sur l'application Web hébergée sur l'adresse IP 192.168.77.26.

Deux analyses complémentaires ont été réalisées:

- Une analyse réseau et services avec **Nmap/Zenmap** ;
- Une analyse de sécurité applicative Web avec **OWASP ZAP**.

L'objectif est d'identifier les services exposés, les informations techniques divulguées ainsi que les principales faiblesses de configuration et de sécurité Web nécessitant une action corrective.

2. Synthèse exécutive

Les analyses réalisées n'ont identifié **aucune vulnérabilité de niveau élevé/critique**.

Le scan Nmap montre une surface d'exposition réseau limitée: seuls les ports TCP **80/HTTP** et **443/HTTPS** sont ouverts parmi les 1000 ports analysés. Les autres ports sont majoritairement filtrés.

Le scan OWASP ZAP a toutefois identifié:

- **3 alertes de niveau Moyen avec confiance élevée** ;
- **4 alertes de niveau Faible** ;
- **9 alertes informatives**.

Les principales faiblesses concernent:

1. L'absence de **Content Security Policy (CSP)** ;
2. Une configuration CSP incomplète ;

3. L'absence de **Subresource Integrity (SRI)** ;
4. La divulgation de la version Nginx ;
5. La divulgation d'informations via X-Powered-By ;
6. L'absence de certains headers de sécurité ;
7. La présence potentielle d'informations sensibles dans les URL ;
8. Un potentiel XSS nécessitant une validation manuelle.

Niveau de risque global

RISQUE MODÉRÉ

La situation ne présente pas, selon les résultats disponibles, de vulnérabilité critique ou élevée. Toutefois, les trois constats de niveau moyen doivent être traités prioritairement et les alertes informatives présentant un potentiel de sécurité doivent faire l'objet d'une validation manuelle.

3. Périmètre du scan

Élément	Valeur
Adresse IP	192.168.77.26
HTTP	http://192.168.77.26
HTTPS	https://192.168.77.26
Nmap	7.95
OWASP ZAP	2.17.0
Ports TCP analysés	1000
Date Nmap	12/08/2026
Date ZAP	14/08/2026

Le scan ZAP a porté sur les interfaces HTTP et HTTPS accessibles sur la cible.

4. Résultats Nmap / Zenmap

4.1 Surface d'exposition

Le scan Nmap a identifié :

Port	État	Service	Version
80/TCP	Ouvert	HTTP	Nginx 1.25.5
113/TCP	Fermé	ident	-
443/TCP	Ouvert	HTTPS/HTTP	Nginx 1.25.5

Sur les 1000 ports TCP analysés:

- 2 ports sont ouverts ;

- 1 port est fermé ;
- 997 ports sont filtrés.

Évaluation

La surface d'exposition réseau apparaît **limitée**.

Aucun service TCP inattendu ou manifestement sensible n'a été identifié dans le périmètre des 1000 ports analysés.

5. Analyse du service HTTP

Le port 80 est accessible et Nmap indique une redirection vers : <https://192.168.77.26/>

Cette configuration est acceptable si le port 80 est conservé uniquement pour rediriger les utilisateurs vers HTTPS.

Recommandation

Vérifier que :

- Toutes les requêtes HTTP sont redirigées vers HTTPS ;
- Aucune donnée sensible n'est transmise via HTTP ;
- Aucune fonctionnalité applicative sensible n'est disponible uniquement en HTTP.

6. Analyse HTTPS / certificat

Le service HTTPS est disponible sur le port 443.

Le certificat présenté possède les caractéristiques suivantes:

Paramètre	Résultat
Autorité	GlobalSign
Clé publique	RSA 2048 bits
Signature	SHA-256
Validité début	09/12/2025
Validité fin	10/01/2027
SAN	.topnet.tn, topnet.tn

Aucune expiration du certificat n'est constatée à la date du scan.

Recommandation

Compléter l'analyse par une vérification détaillée des protocoles TLS et suites cryptographiques autorisés.

Commande recommandée : `nmap -p 443 --script ssl-enum-ciphers 192.168.77.26`

7. Résultats OWASP ZAP

7.1 Répartition des alertes

Niveau	Nombre	Pourcentage
Élevé	0	0 %
Moyen	3	18,8 %
Faible	4	25,0 %
Information	9	56,2 %
Total	16	100 %

Les trois alertes de niveau Moyen présentent une **confiance élevée**.

8. Constats de niveau Moyen

ZAP-01 – Content Security Policy absente

Niveau : Moyen

Confiance : Haute

ZAP indique l'absence d'un header :

Content-Security-Policy

Risque

L'absence de CSP réduit la capacité du navigateur à empêcher certaines attaques d'injection de contenu, notamment certains scénarios XSS.

Action corrective

Mettre en œuvre une politique CSP adaptée à l'application.

Exemple de principe :

Content-Security-Policy: default-src 'self'; object-src 'none'; base-uri 'self';

La politique définitive doit être adaptée aux ressources réellement utilisées par l'application.

Responsable proposé

Équipe DEV / Équipe Web

Priorité

P1 – Haute

ZAP-02 – CSP : directive sans mécanisme de fallback

Niveau : Moyen

Confiance : Haute

Une directive CSP ne dispose pas d'un fallback permettant d'assurer une politique suffisamment restrictive.

Action corrective

Revoir l'ensemble de la politique CSP et définir explicitement les directives nécessaires, notamment :

- default-src
- script-src
- style-src
- img-src
- font-src
- connect-src
- object-src
- base-uri
- frame-ancestors

Responsable

DEV / Web

Priorité

P1 – Haute

ZAP-03 – Subresource Integrity absente

Niveau : Moyen

Confiance : Haute

ZAP détecte des ressources externes chargées sans attribut integrity.

Risque

Si une ressource externe est compromise ou modifiée, le navigateur pourrait charger une version altérée de celle-ci.

Action corrective

Pour les bibliothèques externes compatibles, utiliser :

```
<script  
  src="https://cdn.example.com/library.min.js"
```

```
integrity="sha384-..."  
crossorigin="anonymous">  
</script>
```

Inventorier les ressources JavaScript/CSS provenant de domaines externes avant correction.

Responsable

DEV / Web

Priorité

P1 – Haute

9. Constats de niveau Faible

ZAP-04 – Divulgence X-Powered-By

ZAP détecte la divulgation d'informations via le header :

X-Powered-By

La technologie **Express** est également détectée.

Action

Supprimer le header côté Express :

```
app.disable('x-powered-by');
```

Responsable : DEV

Priorité : P2

ZAP-05 – Divulgence de la version Nginx

Nmap et ZAP identifient :

nginx/1.25.5

Action

Configurer Nginx afin de réduire la divulgation d'informations :

```
server_tokens off;
```

Puis vérifier le résultat avec :

```
curl -k -I https://192.168.77.26/
```

Responsable : OPS / Administrateur Web

Priorité : P2

ZAP-06 – HSTS absent

Le header : Strict-Transport-Security
n'est pas systématiquement présent.

Action

Après validation complète du fonctionnement HTTPS :

Strict-Transport-Security: max-age=31536000; includeSubDomains

Responsable : OPS / DEV

Priorité : P2

ZAP-07 – X-Content-Type-Options absent

Le header suivant est absent :

X-Content-Type-Options: nosniff

Action

Ajouter le header sur les réponses concernées.

Responsable : DEV / OPS

Priorité : P2

10. Constats nécessitant une validation

ZAP-08 – Informations sensibles dans l'URL

ZAP détecte notamment des paramètres tels que :

email
firstname
lastname
phone
address
governorate

Risque potentiel

Les données présentes dans une URL peuvent être enregistrées dans :

- Logs Web ;
- Logs applicatifs ;
- Historique navigateur ;
- Proxies ;
- Solutions de monitoring ;

- Outils d'analyse.

Action

Identifier les paramètres réellement sensibles et privilégier POST ou un mécanisme approprié lorsque ces informations ne doivent pas apparaître dans l'URL.

Priorité : P2 – À vérifier

11. Potential XSS

ZAP a détecté :

User Controllable HTML Element Attribute (Potential XSS)

Confiance : Faible

Cette alerte ne doit pas être considérée comme une vulnérabilité XSS confirmée.

Une validation manuelle est nécessaire conformément à l'OWASP WSTG.

Paramètres à examiner

address
firstname
lastname
phone
governorate
locale
plan

Action

Vérifier si les valeurs fournies par l'utilisateur sont réinjectées dans :

- HTML ;
- attributs HTML ;
- JavaScript ;
- DOM ;

sans encodage/sanitisation approprié.

Priorité : P1 si XSS confirmée / P3 en attente de validation

15. Conclusion

L'analyse combinée Nmap/Zenmap et OWASP ZAP met en évidence une **surface réseau relativement limitée** et l'absence de vulnérabilité critique ou élevée détectée automatiquement.

Les principales améliorations concernent toutefois le **durcissement de l'application Web et de son infrastructure**, en particulier la mise en œuvre d'une CSP, la protection des ressources externes par SRI et le renforcement des headers HTTP.